

Auditrapport OpenMRS webservices.rest

GROEP C8

ATX-2.4 SOFTWARE SECURITY & COMPLIANCE

Inhoudsopgave

1. Executive Summary	2
2. Scope en Context	3
2.1 Scope	3
2.2 Context	3
3. Audit Methodologie	4
4. Risico-analyse en Bevindingen	5
4.1 Samenvatting risicomatrix	5
4.2 Bevindingenregister	6
4.3 Detailbevindingen	7
5. SBOM en Supply Chain Security	8
5.1 SBOM	8
5.2 Snyk SCA-resultaten	8
5.3 SAST en scanbewijs	9
5.4 Supply-chain restrisico	10
6. Beperkingen en Niet-uitgevoerde Items	10
6.1 Pipeline en CI/CD	10
6.2 Security tests	11
6.3 Applicatie, dependencies en platform	11
6.4 Pentestbevindingen met uitgestelde status	12
7. Conclusie en Advies	12
8. Bijlagen en Bewijsvoering	13
9. Openstaande punten voor oplevering	14

1. Executive Summary

De audit richt zich op de OpenMRS REST Web Services Module. Deze module ontsluit medische en herleidbare patiëntgegevens via REST-endpoints en valt daarmee onder een hoog vertrouwelijkheids- en integriteitsrisico.

De belangrijkste conclusie is dat de module aantoonbaar is onderzocht met threat modeling, risicomatrix, SAST, SCA/SBOM, dependency-triage, pentest en logging-analyse. De hertest van 2026-06-15 toont dat anonieme requests naar `cleardbcache` en `settings.form` nu HTTP 401 retourneren en dat `systemsetting` voor de nurse-rol HTTP 403 geeft terwijl admin HTTP 200 behoudt. Voor productie blijft het restrisico echter **middel tot hoog**, vooral door openstaande dependency-CVE's, niet-blokkerende Snyk-gates, stack traces op enkele paden, ontbrekende volledige auditlogging en platformmaatregelen zoals MFA/rate limiting.

Audit opinion: de module is voldoende onderbouwd voor een onderwijsgerichte security-audit, maar is niet productiegeschikt voor gebruik met echte patiëntgegevens zonder opvolging van open P1/P2-risico's rond dependencies, stack traces, logging en platformmaatregelen.

Onderdeel	Auditbeeld
Patiëntdata via standaard REST-resources	Basale autorisatie werkt: anonieme <code>patient-</code> requests geven 401
Speciale beheerendpoints	PT-003/PT-004: anoniem 401; PT-006: nurse 403 en admin 200
Supply chain	SBOM en Snyk aanwezig, maar 106 unieke CVE's en Snyk is geen harde merge-gate
SAST/code review	SAST/code review zijn uitgevoerd; meerdere bevindingen staan nog open of vragen triage
Logging/monitoring	Logging is onderzocht en deels uitgewerkt, maar auditwaardige dekking van kritieke events is nog onvoldoende aangetoond
Productiegereedheid	Niet productiegeschikt voor echte patiëntgegevens zonder opvolging van open P1/P2-items

2. Scope en Context

2.1 Scope

In scope	Buiten scope
Module <code>webservices.rest</code> broncode en <code>.omod</code>	Volledige OpenMRS Core-codebase
REST API, filters, controllers en module-instellingen	Productieomgeving van een zorginstelling
GitHub Actions CI/CD, SAST, SCA en SBOM	Fysieke beveiliging en volledig ISMS
Lokale Docker/OpenMRS testomgeving	Contractueel leveranciersmanagement
Pentest op P1/P2-risico's	Volledige performance- of volumetrische DoS-test

2.2 Context

De module verwerkt of ontsluit onder andere patiëntrecords, identifiers, persoonsgegevens, sessiegegevens, rollen/privileges, observaties, orders, allergieën en systeeminstellingen. Deze gegevens zijn geclassificeerd als hoog risico binnen de BIV/CIA-triad, met name door de combinatie van gezondheidsgegevens, authenticatiegegevens en kritieke medische integriteit.

Belangrijkste brondocumenten:

Document	Rol in audit
docs/auditrapport/00-risk-assessment.md	Overkoepelende risicoanalyse
docs/auditrapport/01-gap-analyse.md	NEN 7510-2 gap-analyse
docs/auditrapport/02-pipeline-compliance.md	CI/CD compliance-by-design
docs/auditrapport/03-assets.md	Asset- en kroonjuweelidentificatie
docs/auditrapport/threat-model.md	C4/threat model en traceerbaarheid
docs/pentest/pentestrapport-definitief.md	Definitieve penteststatus

3. Audit Methodologie

De audit is uitgevoerd als document- en technische security-audit met meerdere bewijsbronnen.

Stap	Aanpak	Bewijs
Asset-identificatie	Kroonjuwelen en CIA-impact bepaald	docs/auditrapport/03-assets.md
Threat modeling	C4-context, trust boundaries, dreigingen	docs/auditrapport/threat-model.md
Risicoanalyse	Kans × impact, risicomatrix en backlog	docs/auditrapport/04-risico-matrix.md , docs/auditrapport/06-security-backlog.md
Bow-tie analyse	Top event T1 en CI/CD secret-leak scenario	docs/auditrapport/05-bowtie.md , docs/auditrapport/04b-cicd-bow-tie.md
SAST	GitHub CodeQL en Snyk Code	docs/auditrapport/08-security-code-review.md , .github/workflows/codeql.yml
SCA/SBOM	Snyk SCA en CycloneDX SBOM	docs/auditrapport/bijlage-dependency-updateadvies.md , docs/auditrapport/bijlage-sbom.cdx.json
DAST/pentest	Burp Suite op lokale OpenMRS testomgeving	docs/pentest/03-bevindingen.md
Compliance mapping	NEN 7510-2 en CRA-koppeling	docs/auditrapport/cra-mapping.md

De gebruikte prioritering is gebaseerd op CVSS, kans × impact, bereikbaarheid vanuit de REST API, impact op patiëntdata en haalbaarheid binnen modulescope.

4. Risico-analyse en Bevindingen

4.1 Samenvatting risicomatrix

ID	Dreiging	Kans	Impact	Score	Niveau	Status
T1	Ongeautoriseerde API-toegang	4	5	20	Kritiek	Deels beheerst; hertest speciale endpoints geslaagd
T4	Credential-lek in repository	4	4	16	Kritiek	Beheersing via scanning/backlog, secret scanning nog aandachtspunt
T2	Blootstelling patiëntdata	3	5	15	Kritiek	Standaard patient-read anoniem geblokkeerd
T3	Manipulatie medische orders/allergieën	2	5	10	Hoog	Gedeeltelijk; extra integriteitscontrole nodig
T5	Supply-chain aanval via CI/CD	2	5	10	Hoog	SAST/SCA/SBOM aanwezig, gates nog niet hard genoeg
T6	Denial of Service REST API	3	3	9	Midden	Rate limiting/brute-force niet volledig getest

Volledige matrix: <docs/auditrapport/04-risico-matrix.md> en <docs/auditrapport/risicomatrixImage.png>.

4.2 Bevindingenregister

ID	Bevinding	Ernst	NEN-control	Backlog	Status	Bewijs
F-01	<code>cleardbcache</code> was anoniem uitvoerbaar	Kritiek	8.3 / 8.26	SEC-019	Opgelost; hertest toont anoniem 401	docs/pentest/bevinding-PT-003-na.md
F-02	<code>settings.form</code> was anoniem bereikbaar en lekte stack trace	Hoog	8.3 / 8.9 / 8.26	SEC-007 / SEC-010	Opgelost; hertest toont anoniem 401	docs/pentest/bevinding-PT-004-na.md
F-03	<code>systemsetting</code> was te ruim toegankelijk voor nurse-rol	Hoog	8.3 / 5.18	SEC-001 / SEC-011	Opgelost; nurse krijgt 403, admin 200	docs/pentest/bevinding-PT-006-na.md
F-04	Stack traces blijven op enkele foutpaden zichtbaar	Hoog	8.26 / 8.28	SEC-010	Open / uitgesteld; ernst afhankelijk van platformcontext	docs/pentest/03-bevindingen.md
F-05	106 unieke dependency-CVE's in Snyk SCA, waaronder 6 Critical en 53 High	Critical/High	8.8 / 5.21 / 5.22	SEC-006	Open; patchgolf 1 nog niet uitgevoerd	docs/auditrapport/bijlage-dependency-updateadvies.md
F-06	Auditwaardige logging dekt nog niet alle kritieke events	Hoog	8.15 / 8.16	SEC-013 / SEC-020	Gedeeltelijk open	docs/auditrapport/09-logging-gap-analyse.md
F-07	MFA, brute-force bescherming en rate limiting zijn platformafhankelijk	Hoog	8.5 / 8.20 / 8.26	SEC-002 / SEC-003 / SEC-004	Open; ernst afhankelijk van platformcontext	docs/auditrapport/06-security-backlog.md

4.3 Detailbevindingen

F-01 - Anonieme `cleardbcache`

Pentest PT-003 toonde aan dat een anonieme gebruiker `POST /ws/rest/v1/cleardbcache` kon uitvoeren met HTTP 204. Dit raakt T1 en T6, omdat een destructieve beheerfunctie beschikbaar was zonder geldige sessie of privilege. De hertest van 2026-06-15 registreert anoniem gebruik als 401.

Restrisico: regressie bij toekomstige wijzigingen aan speciale endpoints.

Bewijs: [docs/pentest/bevinding-PT-003-na.md](#), [docs/auditrapport/08-security-code-review.md](#).

F-02 - `settings.form` en stack trace

Pentest PT-004 liet zien dat `settings.form` anoniem bereikbaar was en interne foutdetails lekte. De hertest van 2026-06-15 toont dat anonieme toegang nu 401 geeft. Dit verlaagt het risico op configuratielekken, maar stack traces op andere paden blijven als apart restrisico open.

Restrisico: foutafhandeling moet modulebreed consistent zijn.

Bewijs: [docs/pentest/bevinding-PT-004-na.md](#), [docs/auditrapport/cra-mapping.md](#).

F-03 - RBAC op `systemsetting`

Een nurse/testrol kreeg eerder te veel toegang tot `systemsetting`. De hertest bevestigt dat nurse nu 403 krijgt en admin 200. Hiermee is het concrete RBAC-issue gedicht, maar fine-grained autorisatie is nog niet voor elk REST-pad volledig bewezen.

Restrisico: ontbrekende autorisatiematrix voor alle resources.

Bewijs: [docs/pentest/bevinding-PT-006-na.md](#), [docs/auditrapport/06-security-backlog.md](#).

F-04 - Stack traces en foutafhandeling

PT-001, PT-005 en PT-007 tonen dat foutresponses op sommige paden interne details kunnen bevatten. Dit is vooral een informatiek: het geeft inzicht in interne classes, privileges, controllers en configuratie.

Restrisico: gerichte aanvallen worden makkelijker door reconnaissance.

Advies: zet stack traces uit in productie en centraliseer exception handling.

Bewijs: [docs/pentest/03-bevindingen.md](#), [docs/auditrapport/08-security-code-review.md](#).

F-05 - Dependency- en supply-chain kwetsbaarheden

Snyk SCA rapporteert 106 unieke kwetsbaarheden over de Maven-modules, waaronder 6 Critical en 53 High. De zwaarste risico's zitten in onder andere Netty, legacy Jackson, Spring, Tomcat/Jasper, PostgreSQL-driver, GraalVM SDK en c3p0. Niet alle dependencies zijn direct door de module te patchen; een deel is platform- of transitive dependency.

Restrisico: bekende CVE's blijven aanwezig zolang patchgolf 1 niet is uitgevoerd.

Advies: voer Golf 1 binnen één sprint uit, plan platformupdates voor Golf 2 en leg risicoacceptatie vast voor Golf 3.

Bewijs: [docs/auditrapport/bijlage-dependency-updateadvies.md](#), [docs/auditrapport/bijlage-sbom.cdx.json](#).

F-06 - Auditlogging en detectie

De loggingdocumentatie toont dat logging is onderzocht en deels geïmplementeerd, maar dat volledige auditwaardige dekking van authenticatie-, autorisatie-, CRUD-, privilege- en incidentevents nog niet volledig is geborgd.

Restrisico: bij incidenten is reconstructie van wie wat deed niet volledig betrouwbaar.

Advies: koppel auditlogs aan centrale opslag/SIEM, definieer verplichte velden en test op mislukte én geslaagde acties.

Bewijs: [docs/auditrapport/09-logging-gap-analyse.md](#), [docs/auditrapport/11-logging-implementatie.md](#), [docs/auditrapport/logging-testresultaat.png](#).

5. SBOM en Supply Chain Security

5.1 SBOM

Eigenschap	Waarde
Formaat	CycloneDX JSON, schema 1.6
Generator	Anchore Syft 1.42.3 via <code>anchore/sbom-action</code>
Auditbijlage	docs/auditrapport/bijlage-sbom.cdx.json
CI-bron	docs/sbom.cdx.json , workflow .github/workflows/sbom.yml
Componenten	82 componenten
Timestamp bijlage	2026-06-03T08:48:41Z

De SBOM is de versie-inventaris. Voor kwetsbaarheidsbeoordeling is Snyk SCA leidend, omdat die CVE-informatie en upgradeadvies koppelt aan de Maven dependency tree. Bereikbaarheid vanuit de REST API en impact op patiëntdata zijn aanvullend door het team beoordeeld.

5.2 Snyk SCA-resultaten

Ernst	Uniek	CVSS-bereik
Kritiek	6	9,1-9,8
Hoog	53	7,1-8,9
Midden	33	5,1-6,9
Laag	14	2,1-3,7
Totaal	106	

Belangrijke geprioriteerde CVE's zijn opgenomen in [docs/auditrapport/bijlage-dependency-updateadvies.md](#). De kern van het advies:

Golf	Termijn	Acties
Golf 1	≤ 1 sprint	Direct uitvoerbare dependency-updates, waaronder <code>commons-codec</code> , Jackson, PostgreSQL-driver, Netty BOM, Tomcat/Jasper en SnakeYAML testscope
Golf 2	Kwartaal/platform	OpenMRS Core, Spring 5→6, c3p0 en Log4j
Golf 3	Risicoacceptatie	Legacy dependencies zonder fix vastleggen met compenserende controles en expiratedatum

5.3 SAST en scanbewijs

Tool	Type	Output/bewijs
GitHub CodeQL	SAST	GitHub Security tab, workflow .github/workflows/codeql.yml
Snyk Code	SAST	<code>snyk-sast.json</code> als CI-artifact; samenvatting in docs/auditrapport/08-security-code-review.md
Snyk test	SCA	<code>snyk-sca.json</code> als CI-artifact; samenvatting in docs/auditrapport/bijlage-dependency-updateadvies.md
Grype	SCA	SARIF-upload naar GitHub Code Scanning (<code>category: grype-sca</code>), workflow .github/workflows/snyk.yml
Syft/CycloneDX	SBOM	docs/auditrapport/bijlage-sbom.cdx.json

Samenvatting uit de security code review:

Bron	Bevindingen	Status
Handmatig + DAST	6	Gevalideerd tegen pentest/code
Snyk Code	42	7 error, 15 warning, 20 note
GitHub CodeQL	3	Open alerts volgens review
SCA/dependencies	106	Zie dependency-updateadvies

Let op: de JSON-artifacts van Snyk/CodeQL zijn in deze repository vooral via CI-referenties vastgelegd. De lokale auditmap bevat de samenvatting en het dependency-updateadvies; voor volledige reproduceerbaarheid moeten de CI-artifacts bij oplevering worden meegestuurd of geëxporteerd.

5.4 Supply-chain restrisico

De pipeline bevat SAST, SCA en SBOM, maar Snyk draait volgens de auditdocumentatie met `continue-on-error: true`. Hierdoor detecteert de pipeline kwetsbaarheden, maar blokkeert zij niet automatisch merges met kritieke of hoge bevindingen. Dat is acceptabel voor de auditfase, maar niet voldoende als productiegate zonder formele triage en risicoacceptatie.

6. Beperkingen en Niet-uitgevoerde Items

Deze sectie legt transparant vast welke maatregelen niet of niet volledig zijn uitgevoerd binnen de modulescope en sprintplanning.

6.1 Pipeline en CI/CD

Item	Reden	Restrisico	Vervolgstep	Acceptatie
Signed commits	Niet in ruleset opgenomen	Geen crypto-borging op commits	Organisatiebeleid bepalen	Acceptabel binnen audit
Dependabot / Dependency Review	Niet volledig gekoppeld	Nieuwe kwetsbare dependencies kunnen via PR binnenkomen	Activeren naast Snyk	Gedeeltelijk
Snyk hard gate	<code>continue-on-error: true</code>	Kritieke/hoge bevindingen blokkeren merge niet automatisch	Hard gate na triagebeleid	Niet productiegeschikt
Secret scanning	Organisatie-/repo-instelling	Secrets kunnen onopgemerkt blijven	GitHub Secret Scanning activeren	Gedeeltelijk

6.2 Security tests

Item	Reden	Restrisico	Vervolgstap	Acceptatie
OWASP ZAP	Burp volstond voor P1/P2-scope	Minder automatische DAST-dekking	ZAP bij release of eindhertest	Acceptabel voor audit
Brute-force test	Niet uitgevoerd op lokale omgeving	Lockout/backoff onbekend	SEC-003 testen via gateway/IdP	Gedeeltelijk
Volumetrische DoS	Buiten scope	Capaciteit en rate limiting niet bewezen	Load/rate-limit test in acceptatie	Acceptabel binnen scope
Hertest na dependency Golf 1	Golf 1 nog open	Patch-effect onbekend	Snyk + smoke/pentest na update	Nog nodig

6.3 Applicatie, dependencies en platform

Item	Reden	Restrisico	Vervolgstap	Acceptatie
Dependency Golf 1	Nog niet uitgevoerd	106 CVE's blijven open	Patch-PR en Snyk-hercontrole	Niet productiegeschikt
Fine-grained autorisatie alle resources	Grote test- en implementatiescope	BOLA/IDOR buiten geteste paden mogelijk	Autorisatiematrix + regressietests	Gedeeltelijk
MFA op REST/API	Platform/gateway-afhankelijk	Gestolen credentials blijven krachtig	IdP/OAuth2/MFA verplichten	Buiten modulescope
Rate limiting en brute-force bescherming	Gateway-afhankelijk	Scraping en credential attacks mogelijk	Gateway-policy toevoegen	Buiten modulescope
Stack traces overige paden	Uitgesteld naar SEC-010	Info disclosure	Productie-default aanpassen	Nog open
Centrale auditlogging/SIEM	Platformafhankelijk	Incidentreconstructie onvolledig	SIEM-koppeling en logretentie	Nog open

6.4 Pentestbevindingen met uitgestelde status

ID	Titel	Restrisico	Vervolgstap
PT-001	Stack traces REST	Info disclosure	SEC-010
PT-002	<code>patient</code> zonder <code>q=</code> geeft 400	Reconnaissance / foutafhandeling	Gewenst gedrag evalueren
PT-005	<code>loggedinusers</code> geeft 500	Info disclosure	SEC-019 / error handling
PT-007	<code>swagger.json</code> stack trace	Interne API-details zichtbaar	SEC-010 / SEC-029

7. Conclusie en Advies

De audit toont voldoende basis voor een onderbouwd security- en compliancebeeld: assets, threats, risico's, pentest, SAST/SCA, SBOM, CRA-mapping en backlog zijn aanwezig. De belangrijkste runtimeproblemen uit de pentest zijn concreet hertest met HTTP 401 voor anonieme `cleardbcache/settings.form-requests` en HTTP 403 voor nurse-toegang tot `systemsetting`, wat het acute risico verlaagt.

Voor definitieve oplevering en reproduceerbaarheid is aanvullende opvolging nodig. Het advies is:

1. Exporteer de volledige Snyk/CodeQL JSON-artifacts uit CI en voeg deze als SAST-bijlage toe.
2. Voer dependency Golf 1 uit en draai Snyk opnieuw.
3. Maak Snyk/CodeQL-triage een harde kwaliteitscontrole of leg afwijkingen formeel vast.
4. Zet stack traces in productie uit en test foutafhandeling op alle publieke paden.
5. Borg auditlogging centraal, inclusief auth-, RBAC-, CRUD- en security-events.
6. Implementeer of documenteer platformmaatregelen: MFA, rate limiting, brute-force bescherming, TLS/HSTS en secret scanning.
7. Voer een korte regressie-hertest uit op PT-003, PT-004, PT-006 en open stack-trace paden vóór eindoplevering.

Eindoordeel: geschikt als auditbaar schoolproject/eindrapport met aantoonbare bewijsvoering, maar niet productiegeschikt voor echte patiëntgegevens zonder opvolging van open P1/P2-items en export van de volledige SAST/CodeQL-artifacts.

8. Bijlagen en Bewijsvoering

Vereiste bijlage	Status	Locatie / toelichting
Traceability matrix	Aanwezig	docs/auditrapport/bijlage-traceability.md koppelt control → bevinding → wijziging → bewijs
SBOM (CycloneDX JSON)	Aanwezig	docs/auditrapport/bijlage-sbom.cdx.json , docs/sbom.cdx.json
SAST-output	Aanwezig	Samenvatting: docs/auditrapport/08-security-code-review.md ; CodeQL SARIF: docs/SAST-Output/actions.sarif , docs/SAST-Output/java.sarif
Snyk-rapport	Aanwezig	docs/snyk-rapport.json , docs/auditrapport/bijlage-dependency-updateadvies.md , workflow .github/workflows/snyk.yml
Risicomatrix	Aanwezig	docs/auditrapport/04-risico-matrix.md , docs/auditrapport/risicomatrixImage.png , docs/auditrapport/risicomatrixImageCICD.png
Bow-tie diagrammen	Aanwezig	docs/auditrapport/05-bowtie.md , docs/auditrapport/04b-cicd-bow-tie.md
Threat models	Aanwezig	docs/auditrapport/threat-model.md , docs/auditrapport/10-attack-surface.md
CRA-mapping	Aanwezig	docs/auditrapport/cra-mapping.md
Pentestbewijs	Aanwezig	docs/pentest/03-bevindingen.md , docs/pentest/evidence/
Security backlog	Aanwezig	docs/auditrapport/06-security-backlog.md
Pipelinebewijs	Aanwezig	docs/auditrapport/02-pipeline-compliance.md , docs/auditrapport/evidence/github-ruleset-main.png , docs/auditrapport/evidence/github-environments-otap.png
Loggingbewijs	Aanwezig	docs/auditrapport/09-logging-gap-analyse.md , docs/auditrapport/11-logging-implementatie.md , docs/auditrapport/openmrs-rest-audit.log
Dependency-updateadvies	Aanwezig	docs/auditrapport/bijlage-dependency-updateadvies.md
Gap-analyse	Aanwezig	docs/auditrapport/01-gap-analyse.md , docs/auditrapport/gap-analyse-nen7510.xlsx

Bronnen	Aanwezig	docs/auditrapport/bijlage-bronnen.md — workshops, normen, tools, CVE-referenties en projectdocumenten
---------	----------	---

9. Openstaande punten voor oplevering

Punt	Eigenaar	Nodig voor definitief rapport
Volledige Snyk/CodeQL JSON-artifacts exporteren uit CI	Team / repo-admin	Ja
Status inconsistenties tussen oudere risicoanalyse en latere hertest nalopen	Team	Ja
Definitieve acceptatie open restrisico's vastleggen	Product owner / docentcontext	Ja

Versie 2.0-concept - 2026-06-18. Samengevoegd eindrapport op basis van bestaande auditdocumenten, traceability matrix en bijlagen.